MacZine

THE MACTECH SOLUTIONS NEWSLETTER
ISSUE N° 008 · JULY 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

EXPLAINER · NIST 800-171

How Your SPRS Score Is Actually Calculated

The DoD Assessment Methodology scores 110 controls on a 5/3/1 weighting and bottoms out at -203. Here is the arithmetic, and how a CO reads it.

BY **MACTECH SOLUTIONS** READING TIME · 4 MIN NIST-800-171 · DFARS · CMMC · SPRS

A SPRS score is not a grade. It is a subtraction problem that starts at 110 and takes away points for every control you have not implemented, and it is the only number about your cybersecurity posture that a contracting officer can look up without asking you a question.

That distinction matters more than most contractors realize. A grade implies a curve, a passing mark, a sense that 85 is respectable. The DoD Assessment Methodology has none of that. It has arithmetic, a floor of -203, and a database entry that persists until you replace it.

FIELD COPY
ISSUE N° 008
NIST 800 171

110

CONTROLS IN NIST SP 800-171 REV 2, THE FULL POSSIBLE SCORE

-203

THE FLOOR - A SCORE CAN GO FAR BELOW ZERO

320

ASSESSMENT OBJECTIVES BEHIND THOSE 110 CONTROLS, PER NIST 800-171A

The arithmetic

Start at 110 - one point for each control in NIST SP 800-171 Rev 2. Then subtract, for every control not fully implemented, a weight of 5, 3, or 1 depending on how much damage its absence does:

- **5 points** for controls whose absence exposes the network broadly. Multifactor authentication. FIPS-validated cryptography. Boundary protection.
- **3 points** for controls with significant but more contained effect.
- **1 point** for controls that matter at the margin - most of the documentation and review requirements land here.

Two subtleties do most of the damage to a first-time self-assessment. The first is that partial credit does not exist. A control is implemented or it is not; "we do this for most systems" scores the same as "we do not do this." The second is that a handful of 5-point controls have sub-items that can be scored separately, so a single weak area can cost more than its headline weight suggests.

Run that subtraction across a program that has never done the work and the result is not 40 or 50. It is negative. A score of -140 is unremarkable for a contractor at the beginning of a Level 2 program, and it does not mean the business is negligent. It means 110 controls is a lot of controls and the weighting is unforgiving.

A negative score is not a scandal. Posting one and then never moving it is.

◆ WHERE THE NUMBER LIVES

Scores are posted in the **Supplier Performance Risk System**, the same database that carries your delivery and quality history. A contracting officer evaluating you sees them together.

What the number does not tell anyone

Here is where most readings of SPRS go wrong. The score says nothing about the size of your assessment scope. A contractor who spent six months building a tightly bounded CUI enclave and scored 92 across it has done vastly more real work than one who scored 105 by declaring that CUI touches only a single laptop nobody uses.

The score is a function of controls met, not of scope defended. That is precisely why the scope conversation - and the System Security Plan that documents it - carries the assessment weight that the number does not. A high score against an indefensible boundary is the most fragile position in the entire program, because the boundary is the first thing a C3PAO will test.

This is also why the number moves in ways that look strange from outside. Scoping a program honestly can *lower* your score, because a wider boundary pulls in systems that were quietly failing controls all along. That is a healthy correction and it feels like a setback.

Reading a score like a contracting officer

The value of the number is comparative and temporal. It answers two questions: how far is this supplier from complete, and are they moving?

A score of 70 posted eighteen months ago and never touched reads worse than a score of 20 posted last quarter with an assessment date that shows recent work. The first is a program that stopped. The second is a program in progress. Scores carry a date for exactly this reason, and the date is doing more work than most contractors give it credit for.

The corollary is uncomfortable but useful: posting an inflated score is the worst available move. It is a written representation to the government about the state of your systems. If a C3PAO assessment or an incident later contradicts it, the gap between what you posted and what was true becomes the government's exhibit - and under the False Claims Act that exposure runs to the affirming official personally, not only to the company.

What to do with your number this quarter

Sort your unimplemented controls by weight, not by effort. Five 1-point documentation gaps take a week and buy you five points. One 5-point control - multifactor authentication across the boundary - may take the same week and buy you five points *and* remove a finding a C3PAO will otherwise open with. The weighting is the DoD telling you which controls it considers load-bearing. Take the hint.

Then re-post. A stale score is a decision, and it is the wrong one.

If you want the arithmetic run against your actual environment rather than a spreadsheet estimate, a readiness scan produces the score, the weighted gap list, and the assessment date you can defend. ◆◆